

OBSIDIAN PROTOCOL

Adversarial Simulation & Detection Engineering
Full Operation & Reasoning Report

VECTOR-I: CVE-2021-41773 / CVE-2021-42013 • VECTOR-II: CVE-2021-4034 (PwnKit)

Generated: 2026-06-28 18:50 UTC

Classification: Educational / Portfolio — Isolated Lab Environment

Intelligence Sources: NVD · CISA KEV · CISA/FBI Advisories · MITRE ATT&CK · OASIS STIX/TAXII

REPORT MAP

Table of Contents

01	Executive Summary
02	Operation Overview & Attack Chain
03	Correlation Engine — Solving Alert Fatigue
04	Purple Team Detection Coverage
05	Risk Scoring Engine Results
06	Detection Coverage Heatmap (MITRE ATT&CK)
07	Telemetry Gap Analysis
08	Rule Quality Analysis (WARDEN)
09	Root Cause Discovery
10	Adversary Emulation Quality Score
11	IOC Confidence & Decay
12	Attack Replay Timeline
13	Blackwell Core — Evidence-Driven Reasoning Layer
14	Related Output Files & Classification

SECTION 01

Executive Summary

75.0% DETECTION COVERAGE	4 TOTAL ATTACK STEPS	6 TELEMETRY EVENTS	18 STIX OBJECTS (IOC)
--	--	--	---

Metric	Value
Total Attack Steps	4
Detection Coverage	75.0%
Average Detection Latency	1.7s
Total Telemetry Events	6
STIX Objects (IOC)	18
Highest Risk	CVE-2021-42013 (60.5/100)

SECTION 02

Operation Overview & Attack Chain

A real CVE chain from the CISA Known Exploited Vulnerabilities (KEV) catalog was reproduced end-to-end in an isolated, internet-disconnected Docker range: an externally facing Apache RCE (VECTOR-I) used to establish a foothold, followed by a local privilege escalation via the PwnKit vulnerability (VECTOR-II) to obtain root. The full lifecycle of this operation — attack, telemetry capture, correlation, detection validation, risk scoring, root cause analysis, intelligence export, and reporting — was automated across the 17-module pipeline summarized in this report, with the Blackwell Core reasoning layer synthesizing every module's output into a single auditable evidence structure.

Stage	Vector	CVE	MITRE	Outcome
Initial Access	VECTOR-I	CVE-2021-41773	T1190	Path traversal -> file read
Execution	VECTOR-I	CVE-2021-42013	T1059	Command execution via CGI redirection
Privilege Escalation	VECTOR-II	CVE-2021-4034	T1548.001 / T1068	Root shell via PwnKit (pkexec)

Why this chain is realistic: the combination of an internet-facing RCE followed by local privilege escalation mirrors the standard structure of real-world intrusions, including the AndroxGh0st botnet campaign documented in the FBI/CISA joint advisory AA24-016A, which chains CVE-2021-41773 with credential-harvesting follow-on activity against more than 30,000 sites (see docs/threat-intelligence.md).

SECTION 03

Correlation Engine — Solving Alert Fatigue

SOC teams routinely face 20,000-200,000+ alerts per day, the overwhelming majority of which are not false alarms but fragments of the same operation that were never tied together. The Correlation Engine groups raw telemetry events by actor identity, time window, and MITRE technique sequence, matching the result against known kill-chain patterns to produce a small number of high-confidence incidents.

Raw Event Count	6
Correlated Incidents	3
Alert Reduction Ratio	50.0%

Severity	Actor	MITRE Chain	Confidence	Narrative
HIGH	ip:172.18.0.3	T1190 -> T1059	95%	'initial_access' from apache_access_log (CVE-2021-41773) followed by 'execution' from apache_access_log (CVE-2021-42013)
MEDIUM	user:1000	T1548.001 -> T1548.001	40%	'privilege_escalation' from ebpf (CVE-2021-4034) followed by 'privilege_escalation' from ebpf (CVE-2021-4034)
LOW	user:1000	T1548.001	20%	'privilege_escalation' from auditd (CVE-2021-4034)

SECTION 04

Purple Team Detection Coverage

Each attack step executed during the operation is checked against the WARDEN module's detection rules (Sigma/auditd/eBPF) to determine whether the step was actually caught, and how quickly.

Vector	CVE	Attack Step	MITRE	Status
VECTOR-I	-	VECTOR-I: Apache version verification (recon)	T1595	MISSED
VECTOR-I	CVE-2021-41773	VECTOR-I: Reading secrets.env via path traversal	T1190	DETECTED (+0.0s)
VECTOR-I	CVE-2021-42013	VECTOR-I: RCE via CGI redirection (command execution)	T1059	DETECTED (+0.0s)
VECTOR-II	CVE-2021-4034	VECTOR-II: Escalation to root via the PwnKit exploit	T1548.001	DETECTED (+5.0s)

SECTION 05

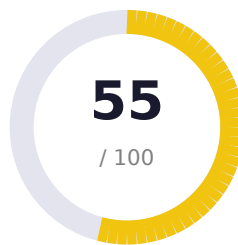
Risk Scoring Engine Results

Risk is computed as a weighted composite of four signals: normalized CVSS, active exploitation in the wild (CISA KEV), campaign breadth (botnet/sector intelligence), and this project's own defense gap (how well WARDEN actually detects each CVE). The same CVSS score can therefore produce different risk scores depending on real-world exploitation and this environment's own detection coverage.

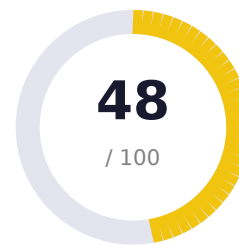
CVE	Risk Band	Score	Rationale
CVE-2021-42013	HIGH	60.5/100	CVSS=9.8 (score:98) KEV=Yes (score:70) Campaign breadth (score:75) Defense gap (score:0, Coverage: 1/1 step(s) detected (100%))
CVE-2021-41773	MEDIUM	54.8/100	CVSS=7.5 (score:75) KEV=Yes (score:70) Campaign breadth (score:75) Defense gap (score:0, Coverage: 1/1 step(s) detected (100%))
CVE-2021-4034	MEDIUM	48.5/100	CVSS=7.8 (score:78) KEV=Yes (score:70) Campaign breadth (score:40) Defense gap (score:0, Coverage: 1/1 step(s) detected (100%))



CVE-2021-42013
HIGH



CVE-2021-41773
MEDIUM



CVE-2021-4034
MEDIUM

SECTION 06

Detection Coverage Heatmap (MITRE ATT&CK)

Three distinct coverage concepts are tracked separately so that “we have a rule” is never conflated with “the rule works”: Rule Coverage (a Sigma/YARA rule exists), Validated Coverage (the rule actually caught an attack in this run), and Observed Coverage (the technique was seen at all during the operation).

Tactic	Validated Coverage	Rule Coverage
Reconnaissance	0.0%	0.0%
Initial Access	100.0%	100.0%
Execution	100.0%	0.0%
Persistence	0.0%	0.0%
Privilege Escalation	50.0%	100.0%
Discovery	0.0%	0.0%

Note: percentages are computed over the set of techniques this project knows about/has labeled, not over all 216 MITRE techniques.

SECTION 07

Telemetry Gap Analysis

Identifies which MITRE tactics this environment cannot observe at all, by checking which of eight common telemetry sources are actually being collected.

Visibility	Tactics
Fully Visible	-
Partially Visible	Defense Evasion, Execution, Initial Access, Persistence, Privilege Escalation
Blind	Collection, Command and Control, Credential Access, Discovery, Exfiltration, Lateral Movement

Recommended Collection Priorities:

1. Start collecting 'NetFlow / Network Traffic Metadata' -> closes these blind tactics: Lateral Movement, Command and Control, Exfiltration, Discovery
2. Start collecting 'EDR (Endpoint Detection & Response)' -> closes these blind tactics: Credential Access, Discovery, Collection
3. Start collecting 'DNS Query Logs' -> closes these blind tactics: Command and Control, Exfiltration

SECTION 08

Rule Quality Analysis (WARDEN)

Writing a Sigma rule is easy; writing a good one is hard. Each detection rule is statically scored across false-positive risk, performance cost, and MITRE/CVE coverage density, rather than just counted.

Rule	FP Risk	Perf. Cost	Coverage
pwnkit_cve_2021_4034.yml	★★★★☆	★★★★☆	★★★★☆
apache_path_traversal_cve_2021_41773.yml	★★★☆☆	★★★★☆	★★★★☆

SECTION 09

Root Cause Discovery

Traces each CVE backward through its causal chain — from the immediate technical flaw to the organizational/process failure that allowed it — and pairs each finding with concrete preventive actions.

CVE-2021-41773 — Outdated Apache HTTP Server (2.4.49)

Outdated Apache (2.4.49, vulnerable version released October 2021) → Weak Patch Policy (the new release was not tested and patched promptly) → Missing Configuration Hardening (the 'Require all denied' default was relaxed) → No WAF (the path traversal pattern was not filtered at the network layer)

Preventive actions:

- Automated patch management (e.g. unattended-upgrades + a staging test pipeline)
- Enforce a 'deny all' default policy in Apache configuration
- WAF rule: block encoded path traversal patterns (%2e%2e/, double-encoding)

CVE-2021-42013 — Incomplete Initial Patch (incomplete fix of CVE-2021-41773)

The first patch (CVE-2021-41773) only addressed single-level encoding → The double-encoding scenario was left outside test coverage → Weak Regression Testing (different encoding variants were not retested after the patch) → mod_cgi left needlessly enabled (made the jump to RCE possible)

Preventive actions:

- Add 'known bypass techniques' to the regression test matrix for security patches
- Keep high-risk modules like mod_cgi enabled only when genuinely required

CVE-2021-4034 — 12+ Year Latent Logic Flaw (polkit pkexec, present since 2009)

polkit pkexec never handling the argc=0 case (a design flaw present since 2009) → No EDR (no memory/syscall-level anomaly detection) → Missing Segmentation (a user with a foothold can reach SUID binaries directly) → auditd unable to catch the exploit ahead of pkexec's own audit code (a visibility gap)

Preventive actions:

- Regular inventory of SUID binaries + removal of unnecessary SUID bits
- eBPF-based syscall monitoring (to close auditd's visibility gap — see the WARDEN module)
- Additional isolation for low-privilege users (e.g. seccomp profiles)

SECTION 10

Adversary Emulation Quality Score

Measures the quality of the red-team operation itself, across attack diversity, MITRE matrix coverage, noise level, and detection success — rather than just whether an operation happened at all.

Attack Diversity	42.9%
MITRE Matrix Coverage	1.39%
Noise Level	High
Detection Success	75.0%
Overall Grade	C (Low diversity/realism)

This project's own MITRE Matrix Coverage is deliberately low: it covers 2 CVEs / 3 techniques against the full 216-technique matrix. This engine reports that ratio honestly rather than inflating its own scope.

SECTION 11

IOC Confidence & Decay

IOCs age. A composite confidence score is computed from exponential time decay (90-day half-life), a log-scaled frequency boost, and a source-diversity boost, banding each IOC into ACTIVE / AGING / STALE / EXPIRED.

IOC	Type	Confidence	Band	Age (days)
GET /cgi-bin/%2e%2e/ (path traversal pattern)	http_pattern	100.0	ACTIVE	1.4
pkexec argc=0 + GCONV_PATH	process_pattern	100.0	ACTIVE	1.4
185.220.101.45 (sample legacy C2 IP)	ip	41.4	AGING	200.8

SECTION 12

Attack Replay Timeline

A minute-by-minute, evidence-timestamped replay of the operation, merging telemetry and Purple Team validation data into a single chronological sequence.

Timestamp	Source	Category	CVE / Technique	Signal
2026-06-27 10:15:00	apache_access_log	unknown	- / -	INFO
2026-06-27 10:15:32	apache_access_log	initial_access	CVE-2021-41773 / T1190	DETECTED
2026-06-27 10:15:40	apache_access_log	execution	CVE-2021-42013 / T1059	DETECTED
2026-06-27 10:18:05	auditd	privilege_escalation	CVE-2021-4034 / T1548.001	DETECTED
2026-06-28 13:08:06	ebpf	privilege_escalation	CVE-2021-4034 / T1548.001	SIGNAL
2026-06-28 13:08:06	ebpf	privilege_escalation	CVE-2021-4034 / T1548.001	SIGNAL

SECTION 13

Blackwell Core — Evidence-Driven Reasoning Layer

Blackwell Core sits on top of the 17-module pipeline above, turning every module's output into a single typed Evidence Graph of claims and the relationships between them (SUPPORTS, CONTRADICTS, CAUSES). Rather than presenting raw dashboards, the Decision Engine synthesizes the graph into a prioritized, explainable action list.

Decision Engine — Prioritized Findings

Rank	Finding	Priority	Risk	Confidence	Root Cause
1	Incident 3b8fb1cb: MEDIUM	0.52	HIGH (63.5)	40%	12+ Year Latent Logic Flaw (polkit pkexec, present since 2009)
2	Incident b2b3dc9b: HIGH	0.46	HIGH (69.75)	95%	Outdated Apache HTTP Server (2.4.49)
3	Incident e023c12b: LOW	0.36	HIGH (63.5)	20%	12+ Year Latent Logic Flaw (polkit pkexec, present since 2009)

Confidence Engine — Multi-Signal Confidence Breakdown

Finding	Confidence	Corrob.	Src. Diversity	Pattern
Incident b2b3dc9b: HIGH	69%	0.80	0.50	0.95
Incident e023c12b: LOW	42%	0.67	0.50	0.20
Incident 3b8fb1cb: MEDIUM	51%	0.75	0.50	0.40

Confidence combines corroboration (independent supporting evidence), source diversity, pattern strength against known kill-chains, and a contradiction penalty — distinct from the Evidence Ranking score, where the confidence term is deliberately inverted (an analyst should look at low-confidence-but-high-severity findings first, not last).

SECTION 14

Related Output Files & Classification

- reporting/navigator/obsidian_protocol_layer.json — ATT&CK Navigator layer file
- docs/detection-coverage-matrix.md — Markdown coverage matrix
- intel-export/output/obsidian_protocol_bundle.stix2.json — STIX 2.1 IOC bundle
- telemetry/output/unified_timeline.ndjson — Raw unified telemetry timeline
- blackwell-core/evidence-graph/output/evidence_graph.json — Full Evidence Graph (BEG)
- blackwell-core/decision-engine/output/executive_briefing.md — Executive briefing
- blackwell-core/decision-engine/output/technical_briefing.md — Technical briefing

Classification: This report was generated automatically from an educational/portfolio adversarial simulation conducted by OBSIDIAN PROTOCOL in an isolated, internet-disconnected Docker range. No real/third-party system was accessed in any way. All intelligence sources referenced (NVD, CISA KEV, CISA/FBI advisories, MITRE ATT&CK, OASIS STIX/TAXII) are public standards.